

Red Teams: наступательный подход к кибербезопасности

 redsec.by/article/red-teams-nastupatelnyj-podhod-k-kiberbezopasnosti

Red Teams | 11 октября 2025



Современные организации сталкиваются с растущим числом целевых атак, которые всё чаще выходят за рамки традиционных сценариев пентестинга. Классические методы проверки защищённости больше не отражают реальную картину угроз. Именно поэтому в корпоративную культуру всё активнее интегрируются **Red Teams** — команды специалистов, моделирующих действия реальных злоумышленников,

чтобы выявить уязвимости не только в технических средствах, но и в процессах, персонале и системах реагирования.

Red Team — это не просто группа пентестеров. Это стратегический инструмент для комплексной проверки устойчивости организации к реальным атакам. Их работа позволяет не только находить слабые места, но и проверять эффективность процессов обнаружения, реагирования и восстановления после инцидентов.

Определение и значимость Red Teams

Red Team (дословно — «красная команда») представляет собой специализированную группу экспертов по кибербезопасности, которая действует от лица потенциального противника. Цель Red Team — не просто взломать систему, а **оценить способность организации противостоять реальной атаке**: обнаружить, локализовать и устранить её последствия.

Главное отличие Red Team от классического пентеста — **реализм и широта охвата**. Если пентестер ищет уязвимости, то Red Team проверяет, готова ли компания к настоящему инциденту.

Ключевые отличия Red Team и пентестинга

Критерий	Red Team	Пентестинг
Цель	Комплексная оценка защищённости, включая способность обнаружения и реагирования	Выявление уязвимостей в конкретных системах
Подход	Скрытные долгосрочные операции, имитирующие APT-атаки	Контролируемое тестирование в заданных рамках
Методы	Социальная инженерия, физическое проникновение, MITRE ATT&CK	Техническое сканирование и эксплуатация уязвимостей
Длительность	От нескольких недель до месяцев	Обычно несколько дней
Осведомлённость	О тесте знает только ограниченный круг лиц	Тест согласован с ИТ-службой

Такой подход позволяет Red Team выявлять уязвимости не только в инфраструктуре, но и в человеческом факторе, цепочках реагирования, организационных процессах.

Роль Red Teams в системе корпоративной безопасности

Интеграция Red Teams в культуру кибербезопасности приносит организациям следующие преимущества:

- **Проверка реальной устойчивости** к сложным целевым атакам;
- **Выявление слабых мест** в процессах обнаружения и реагирования на инциденты;
- **Повышение осведомлённости персонала** о современных угрозах;
- **Оценка эффективности технических и организационных мер защиты.**

Как отмечают эксперты Group-IB, «*Red Teaming позволяет получить полную картину защищённости компании — от инфраструктуры до человеческого фактора*».

Примеры интеграции Red Team в ведущих компаниях

Технологические корпорации

- **Microsoft** применяет **AI Red Team** для тестирования систем искусственного интеллекта, используя инструменты *Microsoft Counterfit* и *PyRIT* для имитации атак на LLM и проверки защиты моделей.
- **Google** создала собственную AI Red Team, которая исследует сценарии атак на ИИ и адаптирует результаты для защиты продуктов компании.

Финансовый сектор

- **Тинькофф Банк** проводит регулярные Red Team операции для проверки защищённости своей экосистемы. Результаты тестов помогают совершенствовать SOC и процессы реагирования.
- **Сбербанк** развернул круглосуточный *Purple-loop* процесс — интеграцию Red и Blue Teams. В сутки анализируется до 7 млрд событий, что позволило полностью исключить утечки в 2024 году.
- **ВТБ** объединил SOC, пентестинг и Red Team, что позволило предотвратить мошеннические операции на сумму 13,5 трлн рублей за год.

Российская практика

- **Positive Technologies** через команду *PT SWARM* активно проводит Red Team проекты с применением техник социальной инженерии, DLL Side Loading и C2-инфраструктуры через Telegram и GitHub.

- **ЦБ РФ** и ряд банков создают внутренние Red Teams, что повышает зрелость отрасли и формирует спрос на специалистов по наступательной безопасности.

Формирование Red Team: структура, навыки и роли

Основные роли

- **Эксперты по наступательной безопасности (Offensive Security)** — поиск уязвимостей, эксплуатация систем.
- **Социальные инженеры** — фишинг, психологическое воздействие, тестирование осведомлённости персонала.
- **Специалисты по сетевым технологиям** — моделирование атак на уровне инфраструктуры и протоколов.
- **Аналитики киберразведки (Threat Intelligence)** — сбор и анализ информации о потенциальных угрозах.

Необходимые компетенции

- Знание архитектуры систем, уязвимостей, векторов атак.
- Понимание стандартов **MITRE ATT&CK**, **OWASP TOP 10**.
- Владение инструментами: *Metasploit*, *Burp Suite*, *Cobalt Strike*, *Kali Linux*.
- Умение применять техники *timestomping*, обхода AMSI и ETW.

Soft skills

- Мышление «как атакующий»
- Креативность и настойчивость
- Этическое суждение и понимание границ тестирования

Организация Red Team процессов

1. **Определение целей:** компрометация ключевых систем, демонстрация доступа, закрепление в домене.
2. **Планирование:** использование MITRE ATT&CK как дорожной карты атак.
3. **Реализация:** скрытое выполнение сценариев в реальном времени.
4. **Документирование:** фиксация каждого шага, каналов атаки, времени реакции Blue Team.
5. **Разбор инцидента:** анализ эффективности защиты и предложений по улучшению.

Важно: работа Red Team проводится **только с согласия руководства** и при строгом соблюдении этических норм, без нарушения целостности и доступности данных.

Оценка эффективности Red Team

Технические KPI

- **MTTD (Mean Time to Detection)** — время от начала атаки до её обнаружения. Цель: менее 24 часов для критических атак.
- **MTTR (Mean Time to Response)** — время от обнаружения до начала активных действий.
- **Глубина проникновения** — уровень компрометации систем и привилегий.

Качественные метрики

- Корректность реагирования Blue Team.
- Полнота контрмер.
- Координация между службами.
- Документирование и анализ инцидента.

Организационные метрики

- **ROI Red Team** — соотношение затрат к предотвращённому ущербу.
- **Соответствие нормативным требованиям.**
- **Снижение страховых рисков и повышение доверия клиентов.**

Долгосрочные показатели зрелости

1. Культура безопасности

- Снижение числа ошибок персонала на 70%
- Повышение уровня осведомлённости
- Формирование проактивного подхода

2. Техническое развитие

- Интеграция Red Team с SIEM/SOAR
- Автоматизация процессов реагирования
- Развитие собственных инструментов тестирования

Интеграция Red Teams в корпоративную культуру — не просто тренд, а необходимый этап зрелости системы кибербезопасности. Она позволяет организациям перейти от реактивной модели защиты к **проактивному управлению рисками**, где проверяется не только устойчивость инфраструктуры, но и готовность людей и процессов.

Успешные кейсы крупнейших компаний показывают: инвестиции в Red Team окупаются многократно — через снижение ущерба от атак, повышение эффективности SOC и рост доверия клиентов к уровню безопасности организации.